

LLM-Driven Retrieval-Augmented Compliance Auditing for Cloud and Web Privacy: A Literature Review

Aaron Joseph Jean
Department of Computer Science
University of Galway
Galway, Ireland
a.jean2@universityofgalway.ie

Abstract—Modern privacy regulations such as the EU General Data Protection Regulation (GDPR), India’s Digital Personal Data Protection Act (DPDP), and the California Consumer Privacy Act (CCPA) require organisations to provide clear, accurate disclosures about data collection and to obtain consent before non-essential tracking. Verifying that a website’s actual runtime behaviour matches the claims in its written privacy and cookie policies, however, remains a manual, error-prone, and unscalable task. This paper reviews research on automated privacy-compliance assessment across three modalities: natural-language processing of policy text, behaviour-to-policy inconsistency detection, and dynamic web consent auditing, together with the emerging use of large language models (LLMs) for legal reasoning. Rather than separating summary from critique, each research direction is reviewed alongside the specific limitation it leaves unresolved. The review shows that existing systems analyse policy text or runtime behaviour in isolation, while the few hybrid systems are confined to static analysis of compiled mobile binaries. From these observations we derive the central research gap: the absence of a unified, automated framework that ingests runtime web telemetry (HAR logs and JavaScript events), retrieves the relevant legal standard, and cross-references both against scraped policy text using retrieval-augmented generation (RAG) to detect real-world non-compliance.

Index Terms—privacy compliance, large language models, retrieval-augmented generation, cookie consent auditing, web telemetry, GDPR, natural language processing

I. INTRODUCTION

With the rise of data privacy laws worldwide, including the EU’s General Data Protection Regulation (GDPR) and India’s Digital Personal Data Protection Act (DPDP), digital transparency has shifted from an ethical preference to a legal mandate. Under these frameworks, organisations are legally required to provide users with clear, detailed, and accurate disclosures regarding data collection, processing purposes, and tracking technologies. Regulations such as the UK’s Privacy and Electronic Communications Regulations (PECR) further require explicit user consent before any non-essential tracking technology, such as cookies or device fingerprinting, is initiated. Empirical studies confirm that these requirements are frequently violated in practice: large-scale crawls of consent banners show that many sites set tracking cookies before any user interaction [1], [2], and automated analyses of written

policies reveal widespread incompleteness and ambiguity [3], [4].

Despite these legal frameworks, real-world compliance is highly fragmented. Many organisations use template-based privacy policies that do not accurately represent their actual technical practices [5]. Conversely, dynamic third-party scripts and marketing pixels are often added to websites without the knowledge of the primary site administrator, leading to silent data leaks and consent violations [2]. Compliance auditing is therefore still performed manually by legal experts and security auditors who inspect website code, examine consent pop-ups, monitor network requests, and read legal documents line by line. This approach is slow, expensive, and unscalable.

A. Motivation

While automated tools have been developed to detect trackers or parse privacy policies, they typically operate in silos. Systems either analyse policy text using natural language processing (NLP) to evaluate readability and completeness [3], [4], [6], or they inspect network traffic to identify tracking scripts and consent violations [1], [2], without cross-referencing the two. The few systems that attempt hybrid auditing are limited to mobile app ecosystems and rely on static program analysis [5], [7], [8], which is prone to false positives from unused libraries and cannot address the runtime complexities of web-based cookie consent banners. In parallel, large language models have begun to demonstrate strong legal-reasoning ability [9], [10], but have not been integrated with live behavioural evidence.

The main research question addressed by the wider project, and motivated by this review, is: *How can privacy compliance of web applications be measured in a continuous, contextual, and explainable manner that connects written disclosures (“notice”) to actual software execution (“practice”)?*

B. Paper Organisation

The remainder of this paper is structured as follows. Section II presents an integrated literature review and gap analysis, including the methodology used to select the reviewed papers, a comparative summary, and a synthesis of the key findings

and resulting research gap. Subsequent sections on the proposed approach, implementation, and evaluation are deferred to later work.

II. LITERATURE REVIEW AND IDENTIFIED GAPS

To build a sound academic foundation, a systematic search was conducted across IEEE Xplore, the ACM Digital Library, the USENIX proceedings, and Google Scholar, using keyword combinations such as *automated privacy policy compliance*, *cookie consent auditing GDPR*, *deep learning privacy policy NLP*, and *LLM legal compliance evaluation*. Papers were included only if they were published in a reputable peer-reviewed venue (e.g., USENIX Security, IEEE S&P, NDSS, ACL, EMNLP, NeurIPS, or PoPETs), presented an automated or semi-automated methodology, and collectively spanned both the textual analysis of legal documents and the technical analysis of software behaviour. This yielded ten representative works, organised below into four research directions. Following recent practice, each direction is reviewed together with the specific gap it leaves open, and Table I consolidates the comparison.

A. NLP and Machine Learning on Privacy Text

Analysing unstructured legal text is the first hurdle in automated compliance checking. Wilson et al. [3] established the foundational benchmark by creating the OPP-115 corpus, manually annotating 115 privacy policies with 23,000 fine-grained data practices and showing that statistical classifiers could automate policy categorisation; however, their models captured only shallow keyword associations rather than deep semantic meaning. Harkous et al. [4] advanced the field with Polisis, training custom word embeddings on 130,000 policies and using convolutional neural networks to classify policy segments at 88.4% accuracy, powering an automated question-answering assistant. Ravichander et al. [6] introduced the PrivacyQA dataset and showed that fine-tuned BERT models could extract answer spans, but reported a large gap between automated models and human legal experts. Crucially, all three rely entirely on the written policy text and have no mechanism to verify whether a site actually follows the stated practices.

Gap identified: Text-only NLP methods assess what a policy says, but cannot verify what a system actually *does* [3], [4], [6].

Adopted in our framework: OPP-115’s ten data-practice categories [3] inform the requirement-type taxonomy used to tag legal chunks; Polisis’ segment-level classification [4] motivates routing only topically relevant policy sections to the scorer for long policies, and its finding that domain-specific embeddings outperform general ones supports the choice of legal-domain embeddings; PrivacyQA’s demonstration that even legal experts disagree on unanswerable questions [6] motivates an explicit NOT-ADDRESSED verdict and confidence output rather than forced binary judgements.

B. Behaviour-to-Policy Inconsistency Detection

A second line of work checks whether disclosures are honest by analysing software behaviour. Zimmeck et al. [5] proposed

a pioneering hybrid system for Android apps, combining text classification with static analysis of bytecode to detect undisclosed collection of sensitive identifiers. They later scaled this to over one million apps in the MAPS project [7], confirming the scale of violations but remaining specific to compiled Android binaries. Xiao et al. [8] shifted the focus to store-mandated privacy labels with Lalaine, characterising widespread non-compliance between Apple privacy labels and observed app behaviour. While these hybrid approaches validate the notice-versus-practice concept, static binary analysis suffers from false positives caused by dead code and, more importantly, cannot capture the dynamic, event-driven behaviour of web applications such as cookie setting and JavaScript-based tracking.

Gap identified: Hybrid notice-versus-practice auditing exists only for mobile ecosystems via static analysis, leaving dynamic web behaviour unaddressed [5], [7], [8].

Adopted in our framework: Zimmeck et al.’s design principle of a closed set of practices checkable in both text and behaviour [5] is mirrored in our mapping of each compliance dimension to a defined behavioural evidence type; MAPS’ conservative reporting of *potential* non-compliance [7] is retained in all generated output; and Lalaine’s typology of non-compliance, *neglect*, *contrary*, and *inadequate* disclosure [8], is adopted to classify every policy-versus-telemetry discrepancy the scorer reports.

C. Dynamic Web Cookie and Consent Auditing

Dynamic auditing of web tracking has been addressed through large-scale crawling. Trevisan et al. [1] performed a longitudinal study of EU cookie-law compliance, introducing an automated tool that detects tracking cookies set before user consent. Bouhoula et al. [2] extended this to the first general, automated, large-scale analysis of cookie-notice compliance, correcting the selection bias of earlier consent-management-platform-specific studies. Both provide strong empirical evidence of widespread violations, but they focus exclusively on observable network and consent behaviour and do not analyse or cross-reference the text of the websites’ written privacy policies.

Gap identified: Dynamic web auditing measures behaviour and consent signals but never reconciles them with the site’s written policy claims [1], [2].

Adopted in our framework: Trevisan et al.’s conservative operational definition of a profiling cookie (third-party, present in the intersection of two curated tracker lists, lifetime of at least one month) and their clean-profile, no-interaction visit protocol [1] are adopted directly by the telemetry collector and HAR evidence extractor; their finding that violations are invariant to client location and browser justifies single-vantage scanning. From Bouhoula et al. [2], whose crawler and classifiers are open source, we reuse the notice-detection heuristics (filter-list matching combined with z-index inspection), the accept/reject/no-interaction action protocol, and feature-based classification of observed cookie purposes, which removes dependence on tracker blacklists; their conservatively tuned

decision-tree mapping from observations to violation types informs our per-dimension verdict rules.

D. LLM-Based Legal and Compliance Evaluation

The most recent direction applies large language models to legal reasoning. Guha et al. [9] released LegalBench, a collaboratively built benchmark of 162 legal-reasoning tasks, demonstrating that modern LLMs can interpret legal clauses but evaluating them only on clean, isolated text. Xie et al. [10] took a significant step toward application, systematising 34 privacy-practice clauses from ten modern privacy laws and using an LLM-based pipeline to evaluate policies collected from over 100,000 websites at scale. While this confirms that LLMs can assess policy text against codified law, the evaluation still operates on policy text alone and does not ingest runtime behavioural evidence such as HAR network logs or JavaScript telemetry.

Gap identified: LLMs can reason over legal text and policies, but no framework feeds them live behavioural telemetry to ground their compliance judgements [9], [10].

Adopted in our framework: LegalBench’s privacy-related tasks [9] serve as a pre-deployment benchmark for selecting the scoring LLM, and its IRAC framing (issue, rule, application, conclusion) structures the scoring prompt: the compliance dimension is the issue, the retrieved article the rule, and the policy text plus behavioural evidence the facts to which it is applied. Xie et al.’s systematisation of 34 clauses across ten laws [10] is used to validate the coverage of our compliance dimensions, and their evaluation protocol, measuring per-clause F1 against an expert-annotated sample, is adopted as the evaluation design for the proposed framework.

E. Synthesis and Research Gap

Reading across the four directions, the reviewed work collectively establishes three findings: (i) written privacy policies are frequently incomplete and ambiguous and fail to disclose active tracking behaviour [3], [4], [6]; (ii) dynamic consent mechanisms on the web frequently set tracking cookies before consent is obtained, constituting measurable GDPR/PECR violations [1], [2]; and (iii) large language models can interpret legal clauses and assess policy text against codified law with growing accuracy, but only on text in isolation [9], [10].

Taken together, these findings expose a clear gap. Each strand masters a single modality, policy text, mobile behaviour, web behaviour, or legal reasoning, yet none reconciles the three sources a compliance judgement actually requires. Existing systems analyse the written policy text in isolation (NLP/LLM approaches) or the software and web behaviour in isolation (dynamic crawls), and the few hybrid systems that match policy to behaviour are restricted to static analysis of compiled mobile binaries [5], [7], [8]. Consequently, there is currently **no unified, automated auditing framework that ingests runtime web behavioural evidence (network HAR logs and JavaScript event telemetry), retrieves the relevant legal standards, and cross-references them against scraped policy texts using LLM-driven retrieval-augmented gener-**

ation (RAG) to detect real-world non-compliance and contradictions. Bridging this divide between disclosed “notice” and observed “practice” for the dynamic web is the objective of the framework proposed next.

III. PROPOSED APPROACH AND METHODOLOGY

The design of the proposed framework is derived directly from the gaps identified in Section II rather than chosen in the abstract. Each gap motivates a specific architectural decision, as summarised in Table II. The central observation is that the four research directions each master one modality, policy text, mobile behaviour, web behaviour, or legal reasoning, but none integrates the three sources of evidence that a real compliance judgement requires: the *law* (ground-truth regulation), the *notice* (the site’s written policy), and the *practice* (its observed runtime behaviour). The proposed framework is therefore organised around triangulating these three sources for the dynamic web, the setting left unaddressed by prior work.

A. Architecture Overview

The framework consists of three phases (Fig. 1):

- 1) **Legal Ingestion (pre-loaded):** Ground-truth regulations (GDPR, DPDP, CCPA, PECR, HIPAA) are parsed and chunked by legal unit (Articles/Sections) to preserve semantic coherence, embedded with a legal-specific model (*nlpueb/legal-bert-base-uncased*), and stored in a persistent vector database. This responds to G4: grounding the LLM in retrievable legal text.
- 2) **Runtime Collection:** For a target site, a headless browser (Playwright) simulates navigation, recording outbound requests as an HTTP Archive (HAR) and logging JavaScript/DOM events (consent clicks, canvas fingerprinting). It also crawls and extracts the written Privacy and Cookie policies into structured text. This responds to G2 and G3: capturing dynamic web behaviour and the policy text together.
- 3) **RAG Compliance Evaluation:** For each compliance dimension, the system retrieves relevant legal articles from the vector store, reads the extracted policy claims, parses the behavioural evidence, and prompts an LLM with the combined *law + notice + practice* context to output a score, cite the breached article, and recommend a fix. This responds to G1: verifying practice against stated notice.

B. Design Rationale

Three decisions follow directly from the literature. First, *legal-specific embeddings* are used because general-purpose models capture only shallow associations on legal text [3], [4]; domain embeddings give terms such as “controller” and “data subject” appropriate legal semantics, improving retrieval quality. Second, *retrieval-augmented generation* is preferred over prompting an LLM alone because, while LLMs can reason about law [9], [10], ungrounded generation risks hallucinated citations; retrieving the exact article before scoring yields traceable, evidence-backed judgements. Third, *runtime*

TABLE I
REPRESENTATIVE RELATED WORK ON AUTOMATED PRIVACY-COMPLIANCE AUDITING

Ref	Focus	Key Contribution	Modality	Dataset / Evaluation	Limitation
[3]	Policy-text corpus	OPP-115 annotated corpus; statistical classification of data practices	Policy text (NLP)	115 annotated policies	Shallow semantics; no behaviour check
[4]	Deep-learning policy analysis	Polisis CNN classifier (88.4%) and QA assistant	Policy text (NLP)	130k privacy policies	Text-only; cannot verify site behaviour
[6]	Policy QA	PrivacyQA dataset; BERT span extraction	Policy text (NLP)	1,750 questions	Large human-model gap; extractive only
[5]	Notice vs. practice (mobile)	Hybrid text + static bytecode analysis	Mobile static	17,991 Android apps	Static; mobile only; false positives
[7]	Compliance at scale	MAPS large-scale automated analysis	Mobile static	1M+ Android apps	Mobile binaries; no dynamic web consent
[8]	Privacy-label non-compliance	Lalaine measures label vs. behaviour gaps	Mobile dynamic/static	iOS apps + label data	iOS labels; not web telemetry
[1]	Cookie-law auditing	Detects pre-consent tracking cookies	Web network	Longitudinal EU crawl	Ignores written policy text
[2]	Cookie-notice compliance	General large-scale consent compliance analysis	Web network/consent	Large-scale web crawl	No policy-text cross-reference
[10]	LLM policy evaluation	LLM assessment of 34 clauses vs. 10 laws	Policy text (LLM)	100k+ website policies	Policy text only; no runtime telemetry
[9]	Legal-reasoning benchmark	LegalBench: 162 legal-reasoning tasks	Legal text (LLM)	162 tasks, 20 LLMs	Isolated clean text; not applied to web

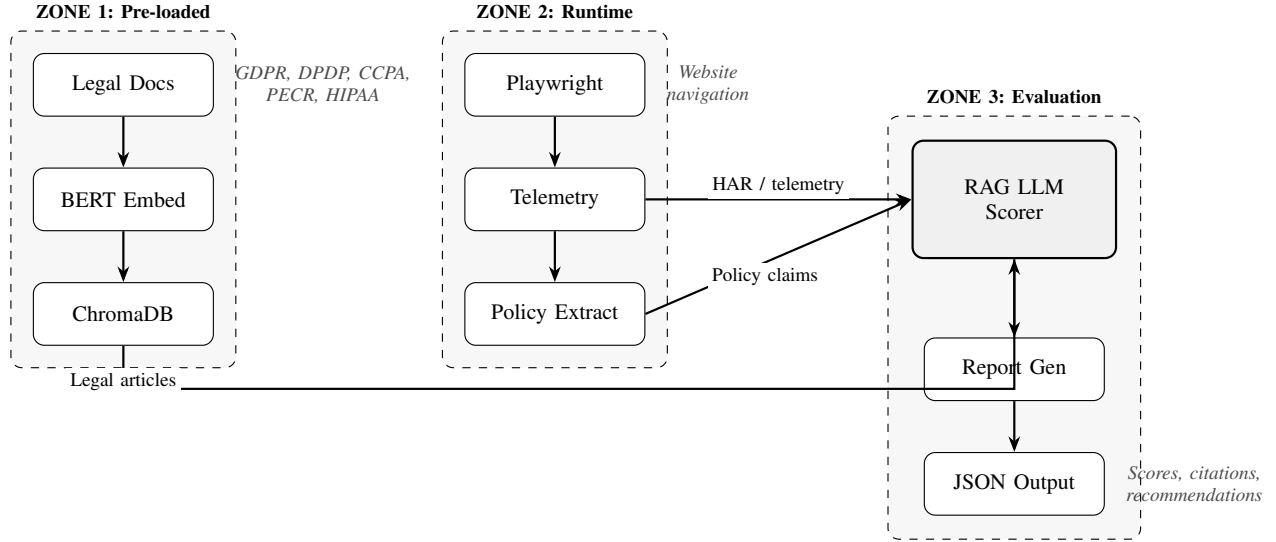


Fig. 1. Proposed architecture. Three phases converge on a RAG-based LLM scorer: (1) pre-loaded legal ingestion into a vector store, (2) runtime telemetry and policy collection, and (3) compliance evaluation that triangulates retrieved legal articles, HAR/telemetry evidence, and extracted policy claims to produce explainable scores and recommendations.

instrumentation (rather than static analysis) is required because the unaddressed modality is dynamic web behaviour, where consent state changes with user interaction, something static mobile analysis [5], [7] cannot observe and text/consent-only studies [1], [2] do not reconcile with policy text. Together these choices make the “notice-to-practice” verification both possible and explainable, the combination absent from all reviewed work.

C. Techniques and Artifacts Adopted from Reviewed Work

Beyond motivating the gap, the reviewed papers contribute reusable techniques, datasets, and open-source artifacts that are incorporated into the implementation. Table III consolidates

this mapping from source to framework component. Publicly released artifacts are reused where licences permit: the crawler and classifiers of [2], the measurement tool and dataset of [1], the OPP-115 corpus [3], the PrivacyQA dataset [6], and the LegalBench task suite [9].

IV. DATASETS

The project uses two complementary dataset categories:

- **Compliance Regulations (static, pre-loaded):** text and PDF sources of the major privacy laws used as ground truth, including GDPR (EU), DPDP (India), CCPA (USA), and PECR (UK).

TABLE II
MAPPING OF IDENTIFIED GAPS TO DESIGN DECISIONS

Gap	Limitation in prior work	Design response
G1	Text-only NLP cannot verify behaviour [3], [4], [6]	Cross-reference policy claims against runtime telemetry (notice vs. practice)
G2	Hybrid auditing limited to static mobile binaries [5], [7], [8]	Dynamic headless-browser instrumentation capturing HAR and JavaScript events
G3	Web auditing ignores written policy text [1], [2]	Couple consent/network evidence with scraped policy extraction per site
G4	LLMs reason over law but lack grounded evidence [9], [10]	RAG over a legal vector store grounds each LLM judgement in retrieved articles

TABLE III
ELEMENTS ADOPTED FROM REVIEWED WORK INTO THE PROPOSED FRAMEWORK

Ref	Adopted element	Framework component
[1]	Conservative profiling-cookie rule (dual tracker-list intersection, ≥ 1 -month lifetime); clean-profile no-interaction visits	HAR evidence extractor; telemetry collection protocol
[2]	Notice-detection heuristics; accept/reject action protocol; feature-based cookie-purpose classification	Consent-interaction module; violation decision rules
[3]	Ten data-practice categories; annotated corpus	Legal-chunk metadata taxonomy; evaluation data
[4]	Segment-level policy classification; domain-specific embeddings	Section routing for long policies; embedding choice
[6]	Unanswerability of some policy questions	NOT-ADDRESSED verdict; confidence output
[5]	Closed set of practices checkable in text and behaviour	Dimension-to-evidence-type mapping
[7]	Tiered analysis for scale; “potential” non-compliance phrasing	Two-tier LLM usage; report language
[8]	Neglect / contrary / inadequate disclosure typology	Discrepancy classification in scorer output
[9]	Privacy-task benchmark; IRAC prompt framing	Scorer-LLM selection; scoring prompt structure
[10]	34-clause systematisation over ten laws; expert-annotated F1 protocol	Dimension coverage validation; evaluation design

- **Website Telemetry (dynamic, collected per scan):** scraped Markdown privacy and cookie policies from target domains; HAR logs capturing runtime HTTP requests, headers, and set-cookie actions; and JSON telemetry capturing JavaScript execution alerts, canvas-fingerprinting calls, and security headers (CSP, HSTS).

TABLE IV
16-WEEK PROJECT PLAN AND MILESTONES

Milestone	Weeks	Key Deliverables
M1: Research & Setup	1–3	Literature review finalised; environment configured
M2: Legal Ingestion	4–6	Document parsing; ChromaDB + legal-BERT embeddings
M3: Telemetry & Crawler	7–9	Playwright automation; HAR logging; policy extraction
M4: Scorer & RAG	10–12	RAG retrieval; LLM prompting; 14-dimension scorer
M5: Eval. & Writing	13–15	Integration testing; documentation; final report
Submission	16	Final submission and presentation

V. PROJECT PLAN AND MILESTONES

The capstone is scheduled over a 16-week timeline divided into five milestones plus final submission. Figure 2 presents the Gantt chart of the schedule, and Table IV lists the key deliverables for each milestone.

VI. POTENTIAL CHALLENGES AND CONSTRAINTS

Several challenges are anticipated for the proposed approach, each with a mitigation:

- **Bot detection on complex sites.** Major platforms (e.g., Meta) block headless clients. *Mitigation:* stealth routing, user-agent randomisation, and loading canonical policy paths where available.
- **LLM context limits and cost.** Full policies (10k+ words) and HAR logs may exceed the context window. *Mitigation:* pre-extract HAR traces into structured evidence snippets (set cookies, unique third-party domains) before prompting.
- **LLM hallucination on legal text.** The model may cite non-existent articles. *Mitigation:* inject the exact retrieved legal text into the prompt so judgements are grounded in verifiable sources (the core motivation for the RAG design).

VII. USE OF AI

In line with the capstone guidelines, the use of AI tools is declared. AI assistance (large language model tools) was used to help format and structure this document, including LaTeX formatting and organising the reference list. All paper selection, literature analysis, identification of the research gap, and the proposed approach are the author’s own work, and the author reviewed and takes full responsibility for the final content.

REFERENCES

- [1] M. Trevisan, S. Traverso, E. Bassi, and M. Mellia, “4 years of eu cookie law: Results and lessons learned,” *Proceedings on Privacy Enhancing Technologies (PoPETs)*, vol. 2019, no. 2, pp. 126–145, 2019.
- [2] A. Bouhoula, K. Kubicek, A. Zac, C. Cotrini, and D. Basin, “Automated large-scale analysis of cookie notice compliance,” in *Proc. 33rd USENIX Security Symposium*, pp. 1723–1739, 2024.

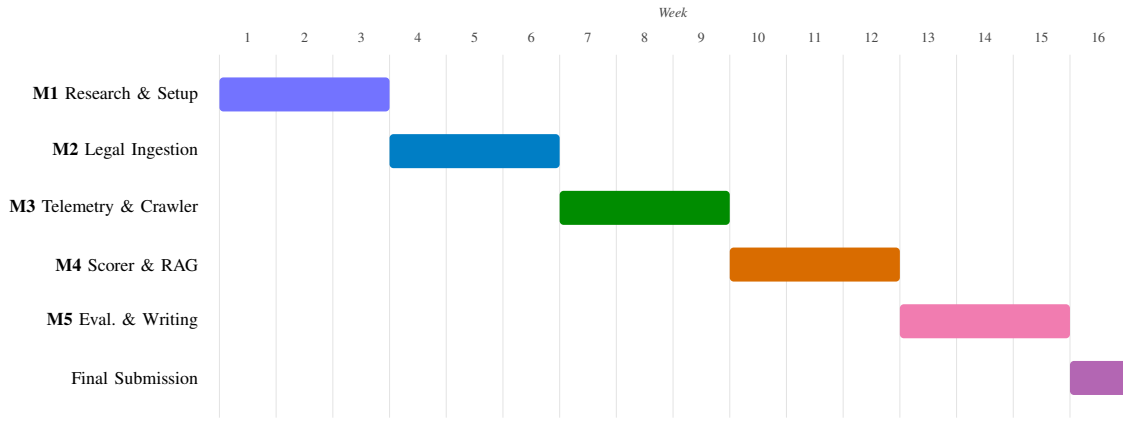


Fig. 2. Gantt chart of the 16-week capstone timeline: five milestones (M1–M5) and final submission.

- [3] S. Wilson, F. Schaub, A. A. Dara, F. Liu, S. Cherivirala, P. G. Leon, M. S. Andersen, S. Zimmeck, K. M. Sathyendra, N. C. Russell, T. B. Norton, E. Hovy, J. R. Reidenberg, and N. Sadeh, “The creation and analysis of a website privacy policy corpus,” in *Proc. 54th Annual Meeting of the Association for Computational Linguistics (ACL)*, pp. 1330–1340, 2016.
- [4] H. Harkous, K. Fawaz, R. Lebre, F. Schaub, K. G. Shin, and K. Aberer, “Polisis: Automated analysis and presentation of privacy policies using deep learning,” in *Proc. 27th USENIX Security Symposium*, pp. 531–548, 2018.
- [5] S. Zimmeck, Z. Wang, L. Zou, R. Iyengar, B. Liu, F. Schaub, S. Wilson, N. Sadeh, S. M. Bellovin, and J. R. Reidenberg, “Automated analysis of privacy requirements for mobile apps,” in *Proc. Network and Distributed System Security Symposium (NDSS)*, 2017.
- [6] A. Ravichander, A. W. Black, S. Wilson, T. Norton, and N. Sadeh, “Question answering for privacy policies: Combining computational and legal perspectives,” in *Proc. Conf. on Empirical Methods in Natural Language Processing (EMNLP-IJCNLP)*, pp. 4947–4958, 2019.
- [7] S. Zimmeck, P. Story, D. Smullen, A. Ravichander, Z. Wang, J. R. Reidenberg, N. C. Russell, and N. Sadeh, “Maps: Scaling privacy compliance analysis to a million apps,” *Proceedings on Privacy Enhancing Technologies (PoPETs)*, vol. 2019, no. 3, pp. 66–86, 2019.
- [8] Y. Xiao, Z. Li, Y. Qin, X. Bai, J. Guan, X. Liao, and L. Xing, “Lalaine: Measuring and characterizing non-compliance of apple privacy labels,” in *Proc. 32nd USENIX Security Symposium*, 2023.
- [9] N. Guha, J. Nyarko, D. E. Ho, C. Ré, A. Chilton, A. Narayana, A. Chohlas-Wood, *et al.*, “Legalbench: A collaboratively built benchmark for measuring legal reasoning in large language models,” in *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2023.
- [10] Q. Xie, K. Ramakrishnan, and F. Li, “Evaluating privacy policies under modern privacy laws at scale: An llm-based automated approach,” in *Proc. 34th USENIX Security Symposium*, 2025.